

Gestão de Cibersegurança

Universidade do Minho

2025/2026

Practical Lab Exercises #09

pg60986 — João Afonso Carneiro Araújo e Silva — MCS

pg59797 — Rui Pedro Ramos Carvalho — MCS

pg60307 — Tiago Leal Baganha — MCS

1.

O produto selecionado foi a aplicação **MB WAY**, uma solução de pagamentos móveis desenvolvida pela SIBS (Sociedade Interbancária de Serviços), que apresenta uma posição de destaque no mercado português. Este produto não se limita a funcionar como uma aplicação móvel, mas também atua como um proxy entre o utilizador, o cartão de crédito/débito e a rede MULTIBANCO. O seu propósito reside na facilidade de transferências imediatas, pagamentos online e criação de cartões virtuais (MB NET). A arquitetura do sistema é fundamentada na associação de um número de telemóvel a um cartão de crédito/débito, de modo que o número de telemóvel passa a atuar como o identificador público da transação, mitigando a exposição direta e a transmissão de dados bancários sensíveis (PAN).

Componentes Principais:

- **Aplicação Móvel (Frontend):** Interface do utilizador que permite a gestão de cartões, a realização de transferências bancárias, a criação de cartões virtuais e o levantamento de dinheiro em caixas MULTIBANCO. Além disso é responsável pelo armazenamento local das chaves criptográficas que autenticam o dispositivo.
- **Back-end da SIBS:** Sistema central que processa e gere todas as transações e estabelece a comunicação entre a aplicação móvel e o sistema bancário.
- **Módulo de Segurança de Hardware (HSM):** Em conformidade com a certificação PCI-DSS da SIBS, é imperativo utilizar hardware criptográfico dedicado para assegurar a gestão segura das chaves e o armazenamento dos dados sensíveis dos cartões (PAN).
- **Sistemas bancários:** Infraestruturas dos bancos aderentes, onde se encontram alojadas as contas dos utilizadores e os respetivos cartões. O MB WAY atua como intermediário, associando o número de telemóvel do utilizador ao seu cartão de crédito ou débito, sem expor os dados do cartão durante as transações.

Ameaças potenciais:

- **Engenharia Social:** Os atacantes manipulam as vítimas (por exemplo, em contextos de vendas online) para que estas associem, em caixas multibanco, o número de telemóvel do atacante à conta bancária da vítima, obtendo controlo total sobre os fundos por meio de MB WAY.

- **Phishing:** A fraude é cometida através de comunicações fraudulentas, nomeadamente e-mails ou SMS, como os alertas universitários, que replicam a identidade do MB WAY. O objetivo é conduzir as vítimas a páginas falsas, visando a recolha de PIN e dados de cartões.

Afirmações de segurança:

- **Garantia de Autorização Explícita e Proteção de Acesso:** O sistema reivindica que a simples posse do dispositivo desbloqueado não autoriza a movimentação de fundos. É assegurado que todas as operações críticas, nomeadamente a efetivação de transações e a geração de cartões virtuais (MB NET), exigem uma validação obrigatória através de PIN de serviço ou biometria no momento da execução. Adicionalmente, o produto permite configurar a exigência destas credenciais logo no arranque da aplicação, protegendo o acesso em caso de comprometimento físico do terminal.
- **Confidencialidade:** O fornecedor assegura que os dados reais do cartão bancário (PAN) nunca são expostos ou transmitidos a comerciantes e destinatários. A arquitetura de segurança baseia-se na utilização do número de telemóvel como identificador público da transação.

[484 palavras]

2.

A análise das alegações de segurança da do MB-WAY à luz da ISO/IEC 15408 exige transformar declarações gerais do fornecedor em requisitos técnicos que possam ser avaliados de forma objetiva.

A primeira alegação garante que o MBWAY garante autenticação forte e multifator, logo o cliente é identificado com pelo menos dois métodos de identificação.

Na estrutura do Common Criteria, esta alegação corresponde principalmente a requisitos relacionados com identificação e autenticação, como FIA_UID.2, que estabelece que o utilizador deve ser identificado antes de qualquer ação, e FIA_UAU.2 ou FIA_UAU.3, que tratam da autenticação com vários fatores. Além disso, FIA_AFL.1 regula a forma como o sistema deve reagir a falhas consecutivas na autenticação, através de limites de tentativas e bloqueios automáticos.

Para verificar esta primeira alegação, seria necessário recolher evidências técnicas que normalmente não são disponibilizadas ao público. Estas evidências incluiriam documentação detalhada sobre o funcionamento da ativação do MB WAY, como os fatores de autenticação se combinam e de que forma a app protege o PIN do utilizador.

Também seriam necessários testes independentes, incluindo testes de penetração, que avaliassem se é possível contornar ou manipular o processo de autenticação. Contudo, existem lacunas importantes, já que a SIBS não publica um *Security Target* nem documentação técnica exaustiva.

Uma métrica possível para quantificar esta alegação seria o número máximo de tentativas de autenticação permitidas antes do bloqueio automático. No entanto, esta métrica tem limitações claras, porque ataques reais contra utilizadores de MB WAY muitas vezes não envolvem tentativas técnicas de quebrar o PIN, mas antes técnicas de engenharia social, logo uma métrica fácil de implementar muitas vezes não será exequível.

A segunda alegação refere que o MB WAY usa comunicações encriptadas e mecanismos de proteção equivalentes aos usados em sistemas bancários europeus. Esta alegação pode ser mapeada para requisitos da ISO/IEC 15408 ligados à criptografia e à proteção de dados em trânsito. Entre estes requisitos, destacam-se FCS_TLSC ou FCS_HTTPS, que regulam o uso correto de protocolos criptográficos; FDP_UCT.1 e FDP_UIT.1, que garantem que os dados transmitidos permanecem confidenciais e íntegros; e FPT_ITT.1, que assegura que os dados processados internamente não são alterados de forma indevida.

Para avaliar esta segunda alegação, seria necessário obter informação detalhada sobre a arquitetura criptográfica usada pelo MB-WAY. Testes práticos deveriam incluir tentativas de atacar a comunicação entre a aplicação e os servidores, nomeadamente ataques do tipo man-in-the-middle.

Uma métrica possível para quantificar esta alegação seria a versão mínima do protocolo TLS suportada. Embora esta medida seja clara, e permita verificar se a app está alinhada com boas práticas modernas, tem limitações: cumprir TLS 1.3, por exemplo, não garante automaticamente uma configuração segura. Existem detalhes importantes, como os

conjuntos de cifras aceites, a forma como as chaves são geridas ou o comportamento da aplicação perante erros de validação de certificados.

No conjunto, a tentativa de medir a segurança do MB WAY usando a ISO/IEC 15408 revela várias dificuldades. A primeira é a escassez de documentação técnica, que limita a capacidade de mapear as alegações do fornecedor para requisitos formais e verificáveis. A segunda é a escassez de documentação técnica, que limita a capacidade de mapear as alegações do fornecedor para requisitos formais e verificáveis. A terceira é que muitas métricas “objetivas” captam apenas aspetos parciais da segurança e não refletem o risco global e a terceira é que o MB WAY depende de componentes fora do seu controlo, como o sistema operativo do dispositivo e o comportamento do utilizado.

[517 palavras]

3.

Tendo em conta as afirmações de segurança referidas anteriormente, a EAL que se assemelha mais ao caso estudado é a **EAL2- Structurally Tested**. O **MB WAY** opera num ambiente de alto risco, que são as transações financeiras móveis, mas ao mesmo tempo é um produto que foi desenvolvido tendo em conta restrições comerciais e com a intenção de ser distribuído em massa. Tal como a ISO/IEC 15408-5 refere, a EAL2 é aplicável em situações em que é exigido um grau moderado ao nível de garantias de segurança, mas onde não existe disponibilidade imediata ou acesso total aos registos completos do desenvolvimento do produto. Esta descrição corresponde à situação do MB WAY, pois apesar de ser uma aplicação que depende bastante da segurança e é distribuída em larga escala, não é expectável que os seus desenvolvedores disponibilizem o conjunto completo de evidências internas exigidas nos níveis de garantia mais elevados, tais como a arquitetura detalhada do sistema, documentação integral do ciclo de vida ou o código fonte. Estes elementos são considerados propriedade sensível da organização e não são habitualmente partilhados publicamente.

O EAL2 inclui componentes como o ADV_FSP.2 (especificação funcional da segurança) e ADV_TDS.1 (descrição simples do desenvolvimento do produto) que permitem comprovar que as funcionalidades de segurança implementadas funcionam de acordo com o que é declarado pelo desenvolvedor. Ao mesmo tempo, esta norma também permite garantir a proteção da propriedade intelectual do fabricante. Assim, a atribuição do EAL2 garante um nível de confiança suficiente para verificar se as medidas de segurança declaradas são eficazes, mas ao mesmo tempo sem exigir evidências impossíveis de obter num produto comercial deste tipo. Todas as medidas essenciais, como a autorização explícita antes de operações sensíveis e a proteção da confidencialidade, são comprováveis através de testes funcionais e documentação fornecida pelo desenvolvedor.

Provas adicionais necessárias para subir de nível

Para que fosse atribuído o nível EAL3, seria necessário disponibilizar informação mais detalhada acerca do desenvolvimento do produto, como:

- Documentação detalhada da arquitetura interna e dos subsistemas;
- Uma maior transparência relativamente às medidas de segurança associadas ao ambiente de desenvolvimento;
- Análise de vulnerabilidades mais profunda, sustentada em documentação técnica

No entanto, a atribuição do EAL3 não seria muito realista para este caso. Este nível exige documentação mais detalhada, como o ADV_TDS.2 (design arquitetural detalhado), ALC_CMC.3 (controles de autorização) e ALC_DVS.1 (identificação das medidas de segurança) o que, para cumprir estes requisitos, seria necessário publicar informação relativa a sistemas internos e medidas de proteção. No caso do MB WAY, uma aplicação bancária móvel, que depende de sistemas operativos externos, algoritmos criptográficos e infraestruturas bancárias distribuídas, disponibilizar esses elementos seria prejudicial e implicaria riscos significativos para a segurança e confidencialidade da própria plataforma.

Limitações na medição

Apesar de adequada, a medição de segurança para o EAL2 apresenta algumas limitações. Em primeiro lugar, o MB WAY depende de componentes externos, como APIs bancárias e sistemas de gestão de chaves criptográficas, que não permitem auditorias. Logo, não é possível medir a robustez dos mecanismos subjacentes à autenticação, autorização ou cifragem, o que pode introduzir lacunas na avaliação. Por esse motivo. Os testes independentes (ATE_IND.2) e a análise de vulnerabilidades (AVA_VAN.2), componentes do EAL2, podem não conseguir cobrir todos os caminhos de execução e não testar ataques sofisticados, pois dependem de informação pública.

Em segundo lugar, parte das afirmações de segurança só pode ser medida ao nível funcional, pois não há acesso ao sistema interno. Por exemplo, a autorização explícita pode ser observada através do comportamento da aplicação, mas não é possível saber se é resistente a ataques sofisticados sem conhecer a lógica interna do MB WAY. Por outro lado, não é possível medir a proteção real da confidencialidade, pois para além das medidas de segurança fornecidas pela aplicação, também depende de fatores externos, como a segurança do dispositivo do utilizador.

Por fim, muitas das métricas normalmente associadas à segurança de produtos bancários móveis, como taxa de burlas através da aplicação, não correspondem a medidas de garantia consideradas no âmbito da EAL2.

Considerações sobre o equilíbrio entre fatores técnicos e económicos

A escolha do EAL2 representa um equilíbrio adequado entre rigor técnico, viabilidade económica e limitações organizacionais. Embora níveis superiores, como EAL3, ofereçam garantias adicionais, a sua implementação implicaria níveis de exposição e custos que não se justificam no contexto de uma aplicação comercial amplamente distribuída. Assim, o EAL2 surge como a solução mais apropriada para o MB WAY, proporcionando confiança independente nos mecanismos de segurança essenciais sem exigir um investimento desproporcionado.

[740 palavras]